

FBLA Cyber Security: *Volume I*

Table of Contents

Defend and Attack.....	1
Disaster Recovery.....	6
Authentication.....	10
Physical Security.....	12
Forensics Security.....	14
Cyber Security Policy.....	15

Defend and Attack

Malware

Adware – *Adware* displays pop-up advertisements to users based on their activities, URLs they have visited, applications that have accessed, and so on.

Virus – *Viruses* get their name from their biological counterparts. They are programs designed to spread from one system to another through self replication and to perform any of a wide range of malicious activities. There are many different types of viruses:

- *Polymorphic viruses* have the ability to alter their own code in order to avoid detection by antivirus scanners
- *Macro viruses* live within documents or emails and exploit the scripting capabilities of productivity software
- *Stealth viruses* attempt to avoid detection by masking or hiding their activities
- *Armored viruses* are designed to be difficult to detect and remove
- *Retroviruses* specifically target antivirus systems to render them useless
- *Phage viruses* modify or infect many aspects of the system so they can be generate themselves from any remaining on remote parts
- A *companion virus* borrows the root filename of the common executable and then gives itself the.com extension in an attempt to get itself launched rather than the intended application

Worms – A worm is malicious software that travels throughout a network without the assistance of a host application or user interaction. A worm resides in memory and is able to different transport protocols to travel over the network.

Spyware – Spyware is software that is installed on a user's system without her awareness or consent. Its purpose is often to take some level of control over the user's computer to learn information and send this information to third party.

Trojan – A Trojan horse is a form of malicious software that is disguised as something useful or legitimate. The goal of a Trojan horse is to trick the user into installing it on the computer. This allows the malicious code portion of the Trojan horse to gain access to the otherwise secured environment.

In Greek mythology, the Achaeans try to sack the city of Troy for several years, but they simply could not succeed. At some point, someone got the idea of building a huge wooden horse and convincing the people of Troy that it was a gift from the gods. Warriors hid inside, and the horse was rolled up to the gates.

The people of Troy party all day and all night, but when the city slept, the Warriors climbed down from the horse and opened the gates, and the rest of the warriors flooded in. What the Greek warriors couldn't do for years, the Trojan horse help them do it in a single day.

Root kits – A root kit is a group of programs that hides the fact that the system has been infected or compromised by malicious code. It does this by embedding itself deep within an operating system (OS). The root kit positions itself at the heart of an OS where it can manipulate information seen by the OS.

Backdoors – the term backdoor can refer to two types of problems or attacks on a system: a developer installed access method that bypasses any and all security restrictions, or a hacker installed remote access client.

Logic bomb – A logic bomb is a form of malicious code that remains dormant until a triggering event occurs. The triggering event can be a specific time and date, the launching of a specific program, or the accessing of a specific URL. Logic bombs can perform any malicious function the programmer wishes, from causing system crashes, deleting data, to altering configurations, distilling authentication credentials.

Botnets – A botnet is a network of robots or malicious software agents controlled by a hacker in order to launch massive attacks against targets. This type of control is used by hackers to read a distributed denial of service (DDoS) attack.

Attacks

DoS (denial of service) – A denial-of-service attack is an attack intended to make a computers resources or services unavailable to users. In other words, it prevents a server from operating or responding to normal requests. Examples would include the SYN flood attack and the Smurf attack.

SYN Flood Attack – the SYN Flood attack disrupts the TCP initiation process by withholding the third packet of the TCP three-way handshake. The TCP three-way handshake goes as follows: first, a client sends a packet with the SYN (synchronization) flag. Next, the server replies with a packet with the SYN and ACK packets to acknowledge the connection attempt. The client replies

with the ACK flag set to confirm the connection. In the SYN flood attack, the third and last packet is never sent which causes the connection to remain half opened consuming resources.

Smurf attack – in a Smurf attack, the attacker sends ICMP broadcast to network with false IP address. Then the network overloads the victim with ICMP response. (Spoofing IP address)

DDoS (distributed denial of service) – a distributed denial of service (DDoS) attack is similar to a denial of service attack except that it includes multiple attacking computers. These attacking computers are often part of a botnet and are often known as zombies.

Spoofing – spoofing is where one person or entity impersonates or masquerades as something else. Spoofing is often used to modify the source IP address or the source email address.

Advanced Attacks

Man-in-the-middle – A man in the middle attack the communications eavesdropping attack. Attackers position themselves in the communication stream between a client and the server.

Replay attacks – A replay attack is just what it sounds like: an attacker captures network traffic and then replays that capture traffic in an attempt to gain unauthorized access to a system.

TCP/IP hijacking – TCP/IP hijacking is where a third party takes over a session and logically disconnects a client that was originally involved in the session.

Social Engineering Attacks

Shoulder surfing – shoulder surfing occurs when someone is able to watch your keyboard or view your display. This could allow them to learn your password or see information that is confidential, private, or simply not for their eyes.

Dumpster diving – dumpster diving is the act of digging through trash in order to obtain information about a target organization or individual.

Impersonations – impersonation is the act of taking on the identity of someone else.

Phishing – Phishing is the practice of sending unwanted email to users with the purpose of tricking them into revealing personal information or clicking on a link. Links within email can also lead unsuspecting users to install malware.

Spear phishing – Spear phishing is a more targeted form of phishing where the message is crafted and directly specifically to an individual or group of individuals, rather than being just a blind broadcast to anyone.

Whaling – whaling is a form of fishing that targets specific high-value targets (by title, industry, from media coverage, and so forth) and sends messages tailored to the needs of and interests of those high-value targets.

Vishing – Vishing is fishing done over VoIP technology.

Piggybacking or tailgating – Piggybacking or tailgating is a practice of one person following closely behind another without showing credentials.

Pharming – Pharming is a malicious redirection of a valid websites URL or IP address to a fake website that hosts a false version of the original valid site.

Hoaxes – a hoax is a form of social engineering designed to convince targets to perform some action that will cause problems or reduced their IT security. It is often an email about proclaims some imminent threat is spreading across the Internet and you must perform certain tasks in order to protect yourself.

POPULAR VIRUSES

The Melissa Virus – the Melissa computer virus tempts recipients into opening a document with an e-mail message like "Here is that document you asked for, don't show it to anybody else." Once activated, the virus replicates itself and sends itself out to the top 50 people in the recipient's e-mail address book.

ILOVEYOU – Unlike the Melissa virus, this threat came in the form of a worm -- it was a standalone program capable of replicating itself. It bore the name ILOVEYOU. The ILOVEYOU virus initially traveled the Internet by e-mail, just like the Melissa virus. The subject of the e-mail said that the message was a love letter from a secret admirer. An attachment in the e-mail was what caused all the trouble. According to some estimates, the ILOVEYOU virus caused \$10 billion in damages

Code Red –When it swept across computers worldwide in 2001, it caught security experts off guard by exploiting a flaw in Microsoft Internet Information Server. That allowed the worm to deface and take down some websites. Perhaps most memorably, Code Red successfully brought down the whitehouse.gov website and forced other government agencies to temporarily take down their own public websites as well.

Nimda – The Nimda worm's primary targets were Internet servers. While it could infect a home PC, its real purpose was to bring Internet traffic to a crawl. It could travel through the Internet using multiple methods, including e-mail. This helped spread the virus across multiple servers in record time. The Nimda worm created a backdoor into the victim's operating system. It allowed the person behind the attack to access the same level of functions as whatever account was logged into the machine currently. The spread of the Nimda virus caused some network systems to crash as more of the system's resources became fodder for the worm. In effect, the Nimda worm became a distributed denial of service (DDoS) attack

MYDoom – Also known as W32.MyDoom@mm, MyDoom is the most destructive computer virus in history. Spotted first in January 2004, the virus rapidly spread through emails, exceeding previous records set by any other worm. Email messages containing the worm were often masked as delivery failures, prompting many to open the message and investigate it. The worm carried two payloads- one

was a backdoor entrance from where the intruder can actually control the infected computer, and the other one was a DDos attack.

Sasser – The Sasser worm was a destructive beast when it hit in 2004. It was created by a 17-year old German kid, who was sentenced to 21 months probation and some community service. The virus did not spread through email, or did not require any human intervention to compromise computers. The virus used RPC Exploit (Remote Procedure Call Exploit) to infect Windows 2000 and Windows XP machines. Sasser targeted universities, hospitals, large corporation, and military organisations, including the British Coast Guard, Agence France-Presse and Delta Airlines. The virus crashed networks from Australia to Hong Kong to the United Kingdom.

Storm – The Storm worm was another worm aimed at a vulnerability in the Microsoft IIS web server. Originally distributed in email messages containing the subject '230 dead as Storm batters Europe', the Storm Worm is a nasty Trojan horse that would further infect the computer with malware once active. Once the worm was activated, it would force the computer to join a Botnet, which are armies of zombie computers that can be used to send out tons of spam. The virus sucked in ten million computers.

FBLA Released Question

_____ encompasses spyware, adware, dialers, joke programs, remote access tools, and any other unwelcome files and programs apart from viruses that are designed to harm the performance of computers on your network.

- a. Spyware
- b. Adware
- c. Grayware
- d. Malware

Competency: Computer Attacks (virus, spam, spyware, etc.)

Task: Identify basic security risks and issues to computer hardware, software, and data.

Answer: C

Disaster Recovery

Disasters

Disasters can be composed of natural disasters such as hurricanes, earthquakes, tsunamis, floods, and tornadoes. Other disasters that may be considered may include fires, attacks, hardware and software failures, or data loss from any cause.

Business continuity

Business continuity is primarily concerned with the processes, policies, and methods that an organization follows to minimize impact of the system failure, network failure, or the failure of any key component need for operation – essentially, whatever it takes to ensure that the business continues, that the show does indeed go on.

Business continuity planning (BCP) is a process of implementing policies, controls, and procedures to counteract the effects of losses, outages, or failures of critical business processes. BCP is primarily a management tool that ensures that *critical business functions (CBF)* can be performed when normal business operations are disrupted.

Two of the key components of BCP are business impact analysis (BIA) and risk assessment.

Business Impact Analysis

The key components of a BIA include the following:

- Identifying Critical Functions
- prioritizing critical business functions
- calculating the time frame for critical system loss
- estimating the tangible and intangible impact on the organization

Risk Assessment

Quantitative Risk Assessment – a quantitative risk assessment measures the risk of using the specific monetary amount. This monetary amount makes it easier to prioritize risks.

Qualitative Risk Assessment – a qualitative risk assessment uses numbers or values to categorize risks based on probability and impact. For example, terms such as low, medium, and high could be used for the numbers one through ten.

Single Point of Failure

Any single component within the system could represent a **single point of failure** if its failure could cause entire system to fail. This could be a single critical server in a multiple server system or critical connection.

Examples of single points of failure – (and the prevention):

- disk subsystem – upgrading disks to RAID
- server providing a critical service – protecting servers using failover clusters
- connections – additional connections can be used to prevent the failure of any single connection

The best way to remove a single point of failure from your environment is to add redundancy.

High Availability

High availability refers to the process of keeping services and systems operation during an outage. With high-availability, the goal is to have key services available 99.999% of the time (also known as five nines availability), which also requires redundancy.

Redundancy

Redundancy refers to systems that are either duplicated or that *fail over* to other systems in the event of a malfunction. *Fail-over* refers to the process of reconstructing a system or switching over to other systems when a failure is detected.

In the case of a server, the server switches to a redundant server when a fault is detected. In the case of a network, this means processing switches to another network path in the event of a network failure in the primary path.

Redundancy: redundant solutions, such as redundant hard drives, redundant servers, and redundant connections, provide high-availability to systems and networks.

Fault Tolerance

Fault tolerance is primarily the ability of a system to sustain operations in the event of a component failure. Fault-tolerant systems can continue operation even though a critical component, such as a disk drive, has failed. Fault tolerance can be built into a server by adding a second power supply, a second CPU, and other key components. There are two key components for fault tolerance you should never overlook: spare parts and electrical power. Since computer systems cannot operate in the absence of electrical power, it is imperative that fault tolerance be built into your electrical infrastructure as well. At a bare minimum, and an *uninterruptible power supply* (UPS) – with surge protection – should accompany every server and workstation. It UPS will allow you to continue to function in the absence of power for only a short duration. For longer durations, you will likely need a *backup generator* that runs off of gasoline, propane, natural gas, or diesel and can generate the electricity needed to provide steady power.

Redundant Array of Independent Disks (RAID)

RAID disks increase performance and provide fault tolerance for disks.

RAID-0

- does not provide any redundancy or fault tolerance

- RAID-0 his *disk striping* – the files are spread across multiple drives
- only results in increased reading and writing performance

RAID-1

- RAID 1 is *disk mirroring* - everything that is stored on one drive is stored on the other
- provides 100% redundancy

RAID-3

- RAID 3 is *disk striping* with a *parity disk*
- parity information is of value based on the value of data stored in each disk location
- RAID 3 is common in older systems, and it's supported by most UNIX systems

RAID-5

- RAID 5 is *disk striping* with *parity* (distributed)
- it is one of the most common forms of RAID in use today
- more space efficiency than RAID-3

RAID-10

- combines RAID-1 and RAID-0 (mirroring and striping)
- it first stripes the data then mirrors and it

Site Redundancy

Hot Site – A hot site would be up and operational 24 hours a day, seven days a week and would be able to take over functionality from a primary site within minutes of a primary site failure. A hot site would include all equipment, software, and network connectivity.

Cold Site – A cold site would have roof, electricity, running water, but not much else. All the equipment, software, and data needs to be brought to the site and enabled.

Warm Site – A warm site is a compromise between a hot site, which is available 24/7, and a cold site, which may be nothing more than a roof, electricity, and running water. Warm sites provide computer systems and compatible media capabilities. If a warm site is used, administrators and other staff will need to install and configure systems to resume operations.

Disaster Recovery

Types of Storage Mechanisms

Working Copies “shadow copies” – are partial or full backups that are kept at the computer center for immediate recovery purposes. They are frequently the most recent backups to have been made and are intended for immediate use.

On-site storage – on-site storage usually refers to a location on the site of the computer center that is used to store information locally.

Off-site storage – off-site storage refers to a location away from the computer center where paper copies and backup media are kept.

Disaster Recovery Plan

The primary emphasis of such a plan is reestablishing services and minimizing losses. The most effective disaster recovery plans include redundancy solutions and backups.

Backup Types

Full Backup – a full backup is a complete, comprehensive backup of all files on a disk or server.

Incremental Backup – an incremental backup is a partial backup that stores only the information that has changed since the last full or the last incremental backup.

Differential backup – a differential backup is similar in function to an incremental backup, but it backs up any files that have been altered since the last full backup; it makes duplicate copies of files that haven't changed since the last differential backup.

All files and backups should be kept at an offsite location known as a data warehouse.

Environmental controls

Fire classes

Class A – Ordinary combustibles	This includes wood, paper, cloth, rubber, trash, and plastics.
Class B – Flammable liquids	This includes gasoline, propane, solvents, oil, paint, and other synthetic or oil based products.
Class C – Electrical equipment	This includes computers, wiring, controls, motors, and appliances Class C fires are often fought by either displacing the oxygen with the gas such as CO₂ or by disrupting the fire's chain reaction with a chemical such as halon. Class C fires should never be fought with water or water base materials since the water is conductive and can pose significant risks to personnel.
Class D – Combustible metals	This includes combustible metals, such as magnesium, lithium, titanium, and sodium.

HVAC – heating, ventilation, and air conditioning (HVAC) systems are important environmental control considerations when planning any computer environment.

A *Faraday cage* can be used to prevent interference and emissions, and a TEMPTESS survey can be accomplished to measure emissions and interferences.

6 Authentication

Core Security Principles

Confidentiality – Confidentiality is implemented to prevent the unauthorized disclosure of data. This is done through methods such as authentication, access controls, and cryptography.

Integrity – Integrity is implemented to verify that data is not modified, tampered, or corrupted. Integrity is enforced by hashing.

Availability – Data and services must be available when they are needed. Availability is reached through methods such as redundancies and backups, covered in the disaster recovery section.

Non-repudiation

Non-repudiation provides definitive proof of a sender's identity and can be used to prevent a party from denying he took a specific action.

Implicit Deny

Implicit deny indicates that unless something is specifically allowed, it is denied.

Three Factors of Authentication

- Something you know (username/password)
- Something you have (smart cards)
- Something you are (fingerprint, biometrics)

Quite frequently, biometrics is susceptible to false acceptance, where an unauthorized user is identified as an authorized user. What we want is true acceptance and true rejection.

Identification vs. Authentication

Identification (Identity proofing) is the process of verifying that someone is who they say they are. Authentication is the act of providing credentials to the authenticator without a human element involved in the process.

Multifactor Authentication

When two or more access methods are included as part of the authentication process, you're implementing a multifactor system. An example of this would be to providing login/password along with another form of authentication such as smart card or biometrics, or in some cases, all of the above.

Kerberos

The authentication mechanism used in domains and UNIX realms. Kerberos requires a key distribution center (KDC) to issue time-stamped tickets and uses port 88. → Kerberos uses symmetric-key cryptog.

Remote Access Authentication

Remote access authentication is used when a user accesses a private network from outside the network, such as using a dial-in connection or a VPN connection. The following are the authentication mechanisms associated with remote access.

PAP

Password authentication protocol (PAP) is used in point-to-point protocol (PPP) to authenticate clients. Passwords are sent in clear text, so PAP is rarely used today.

CHAP

Challenge handshake authentication protocol. CHAP uses a handshake process where the server challenges the client with the nonce (a number used once). The nonce is added to a shared secret, encrypted, and returned to the server for verification.

MS-CHAP and MS-CHAPv2

MS-CHAP was Microsoft's implementation of CHAP, which was dedicated to most of clients only. MS-CHAPv2 was an improvement over MS-CHAP. A significant improvement was the ability to perform mutual authentication.

RADIUS

Remote authentication dial-in user service (RADIUS) decentralized authentication service. Instead of each individual server needing a separate database to identify who can authenticate, authentication requests are forwarded to the central radius server. Example: using Google in Atlanta and using it in Chicago...

TACACS/TACACS+

Terminal access control access-control system (TACACS) and TACACS+ are Cisco's alternatives to radius. Both TACACS and TACACS+ use port 49.

Access Control Models

Mandatory Access Control (MAC)

The MAC model uses sensitivity labels for users and data. Access privileges are predefined and stay relatively static.

Discretionary access control (DAC)

The DAC model specifies that every object has an owner, and the owner has full explicit control of the object. Access is established by the owner, who assigns permissions to users or groups. The owner can easily change permissions, making this a dynamic model.

Role and rule-based access control (RBAC)

RBAC uses roles to grant access by placing users into roles based on their assigned jobs, functions or tasks. It is also referred to as a hierarchical-based model and a task-based model.

Rights and permissions are assigned to the roles. A user is placed into a role, inheriting the rights and permissions of the role.

8 Physical Security

Access Control

These entries must be controlled for the security of the building:

1. Perimeter
2. Building
3. Computer Room

It is also important to make use of physical tokens and proximity cards to secure these areas.

Mantraps

A mantrap is a physical security method in that it creates a buffer zone to a secure area. This will essentially lock some in between this area until security personnel arrive to address the situation. This is meant to combat social engineering techniques such as piggybacking and tailgating.

Hardware Security

This can be composed of adding *cable locks* to your computers to prevent thieves from walking out with a copy of your customer database.

Video Surveillance

Security cameras can be used to monitor situations as well as play a role in the investigation of certain situations.

Environmental Monitoring

Humidity control is important because if the humidity drops much below 50 percent, electronic components are extremely vulnerable to damage from electrostatic shock.

Power Systems

Surge Protectors – Surge protectors protect electrical components from momentary or instantaneous increases (called spikes) in a power line.

Power Conditioners – Power conditioners are active devices that effectively isolate and regulate voltage in a building.

Backup Power – *UPS* (interruptible power supply) gives power for a few minutes while *generators* are used for long term power.

Fire Suppression

Fire Extinguisher Ratings

Type	Use	Retardant Composition
A	Wood and paper	Largely water or chemical
B	Flammable liquids	Fire-retardant chemicals
C	Electrical	Nonconductive Materials
D	Flammable metals	Varies, type specific

Portable fire systems would essentially be fire extinguishers. *Fixed systems* are part of the building, and they're generally water based or gas based.

FBLA Released Question

A prolonged increase in the voltage level is called a:

- a. fault
- b. sag
- c. spike
- d. surge

Competency: Physical Security

Task: Identify and analyze environmental hazards (e.g., fire, flood, moisture, temperature, and electricity,) and establish environmental security controls to protect and restore.

Answer: D

10 Forensics Security

Steps of incident response:

1. identifying the incident
2. investigating the incident
3. repairing the damage
4. documenting and reporting the response
5. adjusting procedures

Preservation of Evidence

Preservation of evidence is issued by ensuring the data is not modified during the collection process. This is often done by first creating a bit copy of the disk.

Chain of custody

A chain of custody should be established as soon as evidence is collected and maintained throughout the lifetime of evidence. It could be documented on a chain of custody form or something else, but it must be documented. A properly documented chain of custody will prove that the evidence presented in a court of law is the same as evidence that was collected.

Sanitizing systems

Systems or drives that contain PII (personally identifiable information) must be sanitized before being disposed of. There are many methods to do so. First is routing patterns of ones and zeros onto the drive. Another option is to degauss the discs, which uses a powerful electromagnetic to make the disk unreadable. And lastly, physical destruction of the discs can render it unreadable.

Basic Forensics associated with Security+

- Act in Order of Volatility: Volatility is thought of as the amount of time you have to collect certain data before that window of opportunity is gone. As an example, the order of volatility in an investigation may be RAM, hard drive data, CDs/DVDs, printouts.
- Document Network Traffic and Logs
- Capture Video
- Record Time Offset
- Capture Screenshots
- Talk to Witnesses

11 Cyber Security Policy

Least Privilege

When assigning permissions, give users only the permissions they need to do the work and no more. The biggest benefit to following this policy is the reduction of risk. *Access creep* is a term used when users have more access than they need. While it can happen as a result of small responsibilities here and there, it can also happen when employees change roles or departments. This additional access opens up weaknesses that increase risk.

Separation of Duties

Separation of duties (SoD) is the concept of having more than one person required to complete a task.

Time of Day Restrictions

Configuring the system to allow accounts access only during certain times during the day.

Mandatory Vacations and Job Rotations

A policy of mandatory vacations should be implemented in order to assist in the prevention of fraud. By moving an employee thorough the organization, you disrupt much of their ability to conduct fraud.

Account Policy Enforcement

Password Length and Complexity

Longer passwords are harder to break.

Passwords that include uppercase and lower case characters, along with numbers and special characters are the strongest.

Password Expiration

The longer the same password is used, the more likely and easier it is to become broken.

Password expirations are usually set at around 90 days, but Microsoft recommends 42 days.

Password Disablement and Lockout

When a user will be gone from a company temporarily (maternity leave, for example), their account should be disable until they return. When a user will be gone forever, their account should be removed from the system immediately.

Privacy Policy + Acceptable Use

All companies should have a privacy policy that states what freedoms and individual has or does not have.

An acceptable use policy defines what is and what is not an acceptable activity, practice, or use for company equipment and resources.

This guide is brought to you by:

Sharma ©